

Open-SDD: Executable Architecture, Zero-Trust Harnessing, and Living Specifications for Enterprise Agentic Software Engineering

Mario Alejandro Ramos* Open-SDD Research & Architecture Initiative

September 2026 (Preprint)

Abstract

As generative artificial intelligence transitions from assistive auto-completion to multi-agent autonomous swarms, enterprise and real-world software engineering confronts an acute governance crisis: stochastic model capacity drastically outpaces deterministic verification. Uncontrolled agentic pipelines routinely amplify write throughput while severely degrading system cohesion, multiplying code duplication and accumulating latent architectural debt.

This paper introduces **Open-SDD**, an open, model-agnostic, zero-trust specification-driven reference harness and methodological toolkit. Grounded in the fifth generation of software abstraction where architectural intent becomes an executable control plane (*SpecOps*), Open-SDD formalizes a four-phase closed-loop cycle: *propose* $\rightarrow$ *act* $\rightarrow$ *verify* $\rightarrow$ *learn*. By deprecating fragmented heuristics and eradicating legacy branded wrappers in favor of unified **sdd-*** protocols and **.sdd/** living trees, Open-SDD introduces five structural innovations: (i) a **Documentary Triad** operating under EARS syntax and persistent Git-native provenance; (ii) a **Strict Git Mode and SpecOps Lifecycle** establishing immutable phase gates, automated branch management, and a zero-tolerance *Gate 0* blocking implementation without human-approved specifications; (iii) an **Adaptive Contextual Decision Engine** (PASS/WARN/ASK/BLOCK) mitigating the empirical *Bypass Conjecture* ($E_{\text{ef}} = E_{\text{nom}}(1 - d(\phi))$) to prevent compliance disabling under false-positive fatigue; (iv) an **Enterprise Agentic Quality Engineering (Agentic QE)** validation substrate operating under the PACTS methodology (Proactive, Autonomous, Collaborative, Targeted, Structured) via Model Context Protocol (MCP) fleets and metamorphic invariants; (v) a **Universal Brownfield Modernization Spectrum** spanning from solo developers and startups to hyperscaler cloud environments (AWS, GCP, Azure) via code-first reverse engineering (**/sdd-getspecs**), Michael Feathers’ Golden Characterization locks, and Martin Fowler’s Strangler Fig pattern; and (vi) native alignment with emergent regulatory frameworks including the EU AI Act (Articles 11–15), NIST AI RMF, and ISO/IEC 42001. We demonstrate how Open-SDD relocates human authority to intent, ethics, and boundary-setting while transforming code into an ephemeral, regenerable commodity.

Keywords: Spec-Driven Development, Agentic Software Engineering, Zero-Trust Architecture, Living Specifications, Universal Brownfield Modernization, Agentic QE, Strict Git Mode, Human-in-the-Loop, AI Governance.

1 Introduction: The Inflection Point of 2026

Three years into the widespread deployment of Large Language Model (LLM) coding assistants, empirical data reveals a striking divergence between perceived acceleration and objective delivery

*Computer Engineer specialising in Spatial Computing & Agentic Architectures, NTT DATA. Email: mario.ramos@nttdata.com

stability. Randomized controlled trials by METR demonstrated that experienced engineers operating AI assistants without formal constraints were up to 19% slower on mature codebases despite self-reporting a 20% speed improvement [1]. Longitudinal source-code evaluations across 211 million lines by GitClear revealed a fourfold multiplication in duplicated code blocks and a decline of refactoring below 10% of total change volume [2]. Similarly, DORA empirical telemetry confirmed that for every 25 percentage-point increase in ungoverned AI adoption, delivery stability suffered a 7.2% degradation [3].

The diagnostic conclusion is unambiguous: **the bottleneck in enterprise agentic engineering is not generative capability, but the absence of a deterministic control plane surrounding a stochastic process.** When left uninstrumented, autonomous agents create state coupling across interdependent components, lack transactional wave atomicity, and suffer from algorithmic collusion when generating and reviewing code within shared context windows.

To solve this dilemma, we present **Open-SDD**, an enterprise-grade, model-agnostic reference harness that transforms architectural specifications from passive, perishable documentation into executable, auditable, and enforceable reality. Open-SDD repudiates proprietary platform lock-in and vendor prefixes (eradicating all historical **kiro-*** baggage), replacing them with an open standard rooted in Git primitives, EARS syntax, and deterministic validation gates across 8 leading agent platforms.

2 Theoretical Foundations: The Fifth Generation of Abstraction

As articulated in recent architectural literature from Red Hat’s Office of the CTO [4], software engineering history is defined by progressive abstraction leaps:

1. **1st Generation:** Machine code (direct binary manipulation).
2. **2nd Generation:** Assembly mnemonics (symbolic processor operations).
3. **3rd Generation:** High-level compiled languages (*C*, Fortran, Java) masking platform instructions.
4. **4th Generation:** Managed memory and dynamic runtimes (garbage collection, virtual machines, declarative infrastructure).
5. **5th Generation (SDD):** Declarative natural and structured intent as the primary executable control surface (*Spec-Driven Development*).

In this paradigm shift, code ceases to be the canonical source of truth. As illustrated in Table 1, SDD enacts a fundamental architectural inversion. Implementation code becomes disposable and regenerable on demand—*Ambient Code*—while the specification repository hosted natively in Git governs the runtime invariant.

Table 1: Architectural Inversion: Classical vs. Open-SDD Model (adapted from [4]).

Dimension	Classical Model (Legacy)	Open-SDD Model
Source of Truth	Source code defines behavior	Executable specifications define behavior
Role of Architecture	Advisory (dormant diagrams in wikis)	Enforceable, executable, and binding
Code Lifecycle	Primary long-term enterprise asset	Ambient code: disposable, reproducible
Drift Detection	Forensic post-facto (production bugs)	Pre-runtime prevention via continuous gates
Runtime Nature	Emergent and unpredictable	Architecturally deterministic
Human Oversight	Forensic code review line-by-line	High-level intent, policy, and boundary gating

3 The Core Architecture: The Propose–Act–Verify–Learn Loop

Open-SDD rejects unconstrained "vibe coding" by encapsulating agent workflows in a closed cybernetic loop:

$$\text{Loop} = \langle \text{Propose} \longrightarrow \text{Act} \longrightarrow \text{Verify} \longrightarrow \text{Learn} \rangle \quad (1)$$

The underlying philosophical principle states: *the model proposes, the harness disposes.*

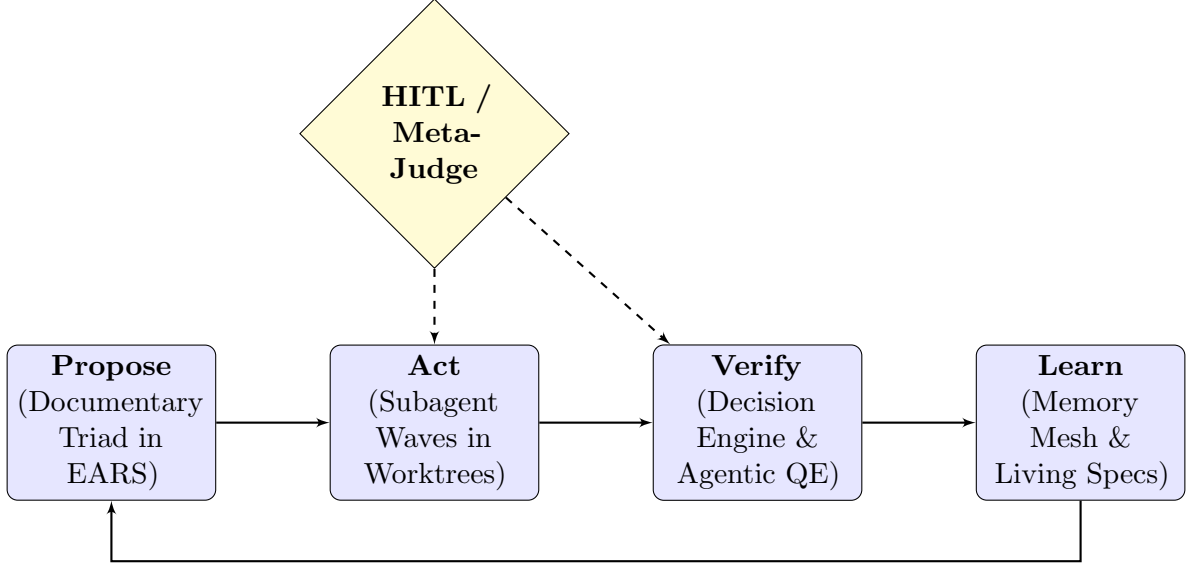


Figure 1: The Open-SDD cybernetic control envelope with Meta-Judge, HITL oversight, and Agentic QE validation.

3.1 1. Propose: The Documentary Triad

No generation proceeds without a bounded specification structured into three synchronized artifacts stored in `.sdd/specs/<feature>/`:

- **requirements.md**: Expressed strictly in **EARS** (Easy Approach to Requirements Syntax) [7]. All acceptance criteria must follow ubiquitous, event-driven, state-driven, or unwanted behavior patterns (e.g., *WHEN [event] THEN the system SHALL [action] WHERE [constraint]*).
- **design.md**: Component topologies, schemas, interface contracts, and immutable **Architecture Decision Records (ADRs)**.
- **tasks.md**: Directed Acyclic Graphs (DAG) organizing atomic, test-driven execution waves with explicit dependency annotations (`_Depends:_`, `_Boundary:_`).

3.2 2. Act: Transactional Worktrees and Subagent Roles

To prevent mutable state races, each task executes within an isolated Git worktree on an ephemeral wave branch. Parallel tasks share no dirty filesystem. If a sub-task fails its acceptance criteria, its worktree is discarded; the primary repository state remains untainted by construction. Rollback ceases to be a manual emergency procedure and becomes the automatic abandonment of an unmerged branch.

3.3 3. Verify: The Bypass Conjecture and Contextual Decision Engine

A central theoretical finding of Ramos [5] is that rigid binary gating induces governance self-destruction:

$$E_{\text{ef}}(\phi) = E_{\text{nom}}(\phi) \cdot (1 - d(\phi)) \quad (2)$$

where E_{nom} is the nominal enforcement rate, ϕ is the false-positive rate, and $d(\phi)$ is the human-induced disablement probability. When a harness raises false alarms on harmless representations (e.g., flagging `rm -rf` within a test fixture or cleaning up a mock sandbox), developers predictably export bypass variables (e.g., `BYPASS=1`), driving real security $E_{\text{ef}} \rightarrow 0$.

Open-SDD resolves this through a 6-dimensional **Contextual Decision Engine** (evaluating phase, environment, surface, artifact type, model confidence, and risk score) producing four graduated verdicts:

- **PASS**: Benign representations confirmed in non-executable fixtures or documentation.
- **WARN**: Acceptable process debt recorded in the audit trail without pipeline termination.
- **ASK**: Ambiguous boundary detection requiring Human-in-the-Loop (HITL) approval via single-use, hash-bound digital receipts.
- **BLOCK**: Unconditional halt reserved for confirmed critical execution risks (e.g., unverified destructive shell commands, live credential exfiltration).

3.4 Enterprise Validation: Autonomous Quality Engineering (Agentic QE) and PACTS

While classical software quality assurance relies on static test suites and manual post-facto assertions, enterprise SDD requires continuous, autonomous validation capable of keeping pace with high-throughput multi-agent code generation. To address this, Open-SDD integrates the **Agentic QE Framework** [9], transitioning quality assurance from an isolated, downstream activity into an autonomous, orchestrating substrate.

Under this paradigm, quality validation is governed by the **PACTS** methodology [9,10]:

- **Proactive**: Defect anticipation and regression risk modeling prior to commit, preventing invariant violations before state transitions occur.
- **Autonomous**: Decentralized QE agents automatically generate metamorphic test cases, property-based invariants, and characterization suites for legacy brownfield monoliths without requiring manual test scripting. Formally, for any invariant relation R over input space $\mathcal{D}$, the QE agent verifies:

$$\forall x, x' \in \mathcal{D}, \quad R(x, x') \implies R(\mathcal{F}_{\text{legacy}}(x), \mathcal{F}_{\text{modernized}}(x')) \quad (3)$$

- **Collaborative**: Peer co-orchestration where autonomous QE agents challenge developer subagents through adversarial verification (`sdd-review`) under human architectural governance.
- **Targeted**: Dynamic scoping where test generation and execution are strictly bounded to the topological blast radius ($\text{Boundary}(T_i)$) specified in `tasks.md` and `design.md`.
- **Structured**: Deterministic observability and structured quality telemetry that output machine-verifiable evidence matrices into `sdd-audit`, prioritizing verifiable empirical confidence over model trust.

3.5 4. Learn: Memory Mesh and Anti-Poisoning Quarantine

Knowledge gained during development is partitioned into a dual-memory system:

- **Session/Temporal Memory** (`.sdd/memory/session/`): Compressed ledgers retaining transient decisions and pruned logs to comply with token budget constraints.
- **Structural Knowledge Graph** (`.sdd/memory/graph/`): A repository-wide index mapping symbols, imports, and AST blast radii (*Graph before Grep*).
- **Anti-Poisoning Quarantine**: Prevents indirect prompt injection by demanding that lessons captured upon gate failures pass a temperature-zero curator screening and cryptographic provenance signature before promotion to permanent steering.

4 Strict Git Mode & The SpecOps Lifecycle: Spec-as-Code

A core vulnerability in contemporary AI coding harnesses is the silent divergence between project specifications and production repositories. In Open-SDD, specifications are treated with identical rigor to production source code: *Spec-as-Code*.

Under **Strict Git Mode** (`.sdd/settings/git.json`), the development lifecycle is mapped directly onto a deterministic Git state machine:

$$\text{State}_{\text{Git}} = \langle \text{Init Seed} \longrightarrow \text{Feature Branch} \longrightarrow \text{Spec Lock} \longrightarrow \text{Gated Impl} \longrightarrow \text{Verified Push} \rangle \quad (4)$$

4.1 The Gate 0 Invariant

Open-SDD enforces a strict precondition prior to any code alteration. The implementation command (`/sdd-impl`) executes an immutable pre-flight check designated as **Gate 0**:

$$\text{Gate}_0(F) = \begin{cases} \text{AUTHORIZED}, & \text{if spec.json.phase} = \text{"approved"} \wedge \text{Approvals}(F) = \text{True} \\ \text{HALTED}, & \text{otherwise (Returns E_SPEC_UNAPPROVED)} \end{cases} \quad (5)$$

If a developer or subagent attempts to generate implementation code while `spec.json` remains in phase: `"initialized"` or unapproved draft state, the execution engine halts immediately. Implementation without an approved specification is strictly blocked by construction.

4.2 Automated SpecOps Automation

Upon human approval of the Documentary Triad (`requirements.md`, `design.md`, `tasks.md`), Open-SDD triggers automated Git orchestration:

1. **Branch Isolation**: Switches context to an isolated branch `feat/Slug(F)` branched from the base branch.
2. **Spec Lock Milestone**: Commits the approved specification bundle with a standardized milestone signature (`spec(slug): lock approved documentary triad`) and pushes to origin.
3. **Verified Implementation Push**: Following successful task completion and Agentic QE verification (`/sdd-validate-impl`), Open-SDD commits the verified implementation, pushes the branch, and automatically drafts a pull request linking all verification evidence to the originating specification.

5 Karpathy Behavioral Directives Mechanized

Informal practitioner wisdom, notably synthesized by Andrej Karpathy [6], highlights recurring LLM failure modes: overcomplication, premature abstraction, and scope drift. Open-SDD elevates these behavioral rules into machine-enforced constraints:

Table 2: Mechanization of Karpathy Guidelines in Open-SDD.

Guideline	Open-SDD Mechanism	Operational Invariant
Think Before Coding	Discovery Phase (<code>sdd-discovery</code>)	Prohibits silent assumption; forces clarifying dialogue before spec initialization.
Simplicity First	Hard Gate	Forbids single-use abstractions, unrequested configurability, and excessive diffs.
Surgical Changes	Boundary Gate	Restricts file writes strictly to declared task boundaries; rejects "polishing" untouched code.
Goal-Driven Execution	Verify Gate (<code>sdd-verify</code>)	Rejects task completion without captured exit codes, passing assertions, and fresh stdout evidence.

6 Universal Brownfield Modernization: From Solo Developers to Hyperscalers

Empirical software engineering data demonstrates that **over 90% of all real-world development occurs in brownfield environments**—codebases with existing architecture, operational constraints, and latent business logic. Greenfield development is the exception; legacy is the universal norm.

A critical design criterion for Open-SDD is that **brownfield modernization is not restricted to heavy enterprise bureaucracy**. Open-SDD formalizes a scalable, multi-tier spectrum that adapts dynamically to organizational scale while preserving behavioral correctness.

6.1 The Four-Tier Brownfield Spectrum

Table 3: The Open-SDD Universal Brownfield Spectrum across Organizational Scales.

Dimension	Tier 1: Solo / Freelance	Tier 2: Startup / SMB	Tier 3: Scale-Up / OSS	Tier 4: Enterprise / Hyperscaler
Primary Goal	Grounding & zero amnesia	Shared memory, no debt	Boundary decoupling	Zero-Trust & compliance
Bootstrap Entry	<code>/sdd-getspecs</code> (quick)	<code>/sdd-getspecs</code> (module)	<code>/sdd-getspecs</code> + Gap	AST Graph + Blast Matrix
Test Focus	Existing unit tests	Unit + Integration in PR	Boundary-scoped suites	Agentic QE (PACTS invariants)
Approval Gate	Fast-track (<code>-y, --auto</code>)	Team peer review	PR spec approval in Git	Strict Git Mode + Human Gate 0
Compliance	None (lean)	PR and changelog trails	ADR decision logs	<code>sdd-audit</code> (EU AI Act, NIST)
Migration Pattern	In-place surgical refactor	Feature-flagged service	Strangler Fig proxy	Multi-Cloud Canary / Mirroring

- **Tier 1: Solo Developers & Freelancers (*Frictionless Brownfield*)**: Addresses prompt amnesia and model hallucinations when returning to repositories after months. Running `/sdd-getspecs` extracts existing stack conventions into `.sdd/steering/`, ensuring subsequent commands modify existing code surgically without rewriting file trees or inventing incompatible dependencies.
- **Tier 2: Startups & Small Teams (*Agile Anti-Debt*)**: Eliminates the "tribal knowledge" bottleneck (bus factor = 1). Reverse-engineering generates a living roadmap in `steering/roadmap.md`, cutting developer onboarding time from weeks to minutes while enforcing independent peer reviews via `sdd-review`.

- **Tier 3: Scale-Ups & Open Source (*Modular Modernization*):** Prevents monolithic coupling. Uses `/sdd-validate-gap` to calculate dependency blast radiuses before code changes. Tasks are strictly constrained to bounded seams (`_Boundary:_`), enabling atomic waves without merge conflicts.
- **Tier 4: Enterprise & Hyperscalers (*Zero-Trust Regulated Modernization*):** Designed for mission-critical core systems running on AWS, Google Cloud, and Microsoft Azure. Operates under the comprehensive 5-Layer Modernization Protocol detailed below.

6.2 The 5-Layer Enterprise Modernization Protocol

For high-assurance, multi-million-line legacy systems, Open-SDD enforces five sequential containment layers:

1. **Layer 1: Structural Reconnaissance (*Graph before Grep*):** Zero-LLM-cost AST dependency extraction (via Tree-Sitter and Language Server Protocols) maps afferent/efferent couplings into `.sdd/memory/graph/`. This generates an explicit blast radius matrix prior to token generation.
2. **Layer 2: Golden Characterization Locking:** Rooted in Michael Feathers' seminal legacy methodology [11], Open-SDD deploys Agentic QE to generate black-box characterization tests that freeze current observable behavior B_0 into Git. Any refactor that deviates from B_0 without explicit specification clearance trips an unconditional halt.
3. **Layer 3: Living Spec Reverse-Engineering (`sdd-getspecs`) and Human Gate:** Ingestion generates unapproved spec seeds (`brief.md`, `spec.json` initialized with approvals unset, and empty EARS stubs). Human architects must review, calibrate business rules, and sign off before implementation is unlocked.
4. **Layer 4: Transactional Surgical Implementation (`sdd-impl`):** Leverages Martin Fowler's Strangler Fig pattern [12] and ephemeral Git worktrees. New capabilities execute behind routing proxies or feature flags, isolated from production code paths.
5. **Layer 5: Enterprise Governance & Compliance Ledger (`sdd-audit`):** Produces immutable verification ledgers connecting every modified source line to its task ID, ADR justification, EARS requirement, and Agentic QE test evidence.

6.3 Hyperscaler Cloud Integration Patterns

In cloud environments, Open-SDD integrates with native traffic steering mechanisms:

- **AWS:** Application Load Balancers (ALB) with weighted target groups route canary traffic to modernized ECS/EKS microservices, while AWS VPC Traffic Mirroring verifies bit-level response equivalence against legacy services in shadow mode.
- **Google Cloud:** Cloud Run and Traffic Director orchestrate incremental traffic splitting ($1\% \rightarrow 10\% \rightarrow 100\%$), with Google Cloud Trace validating latency invariants.
- **Microsoft Azure:** Azure Front Door and Container Apps handle URL rewrite rules, while Azure Chaos Studio evaluates failure resilience under degraded dependency conditions.

7 Auditability, Traceability, and Regulatory Compliance

In heavily regulated environments, an untraced architectural decision is an unauthorized decision. Open-SDD incorporates a dedicated compliance audit command (`sdd-audit`) that compiles machine-readable and PDF reports answering key regulatory mandates:

- **EU AI Act Compliance:** Full traceability of technical documentation (Art. 11), automatic logging of autonomous sessions (Art. 12), and quantified human oversight logs (Art. 14).
- **NIST AI RMF & ISO/IEC 42001:** Continuous risk mapping and verifiable control evidence bound to git commit trailers.
- **Decision Genealogy:** Every deployed function links bi-directionally to its originating EARS requirement ID, ADR justification, executing agent model hash, and verifying human approver.

8 Open Challenges and Future Research Directions

While Open-SDD establishes a robust reference harness, several foundational challenges remain open for active investigation:

1. **Dynamic Formal Verification and SMT Solvers:** Integrating theorem provers and SMT solvers (such as Z3 or Lean 4) directly into the verify gate to prove semantic equivalence between legacy code and regenerated ambient code mathematically.
2. **Decentralized Cross-Repository Spec Federation:** Extending living specifications across heterogeneous micro-frontend and multi-repo architectures without introducing centralized bottleneck repositories.
3. **Dynamic Token Economy Optimization:** Balancing the financial and computational cost of multi-agent autonomous testing fleets against the risk profile of individual software boundaries.

9 Conclusion

Open-SDD demonstrates that autonomous software development at scale does not require larger models; it demands disciplined, deterministic harness engineering. By treating specifications as living, versioned source code in Git, formalizing universal brownfield modernization across all organizational scales, mechanizing Karpathy’s surgical simplicity, and integrating autonomous Agentic QE validation, Open-SDD provides the foundational infrastructure necessary to turn stochastic agentic generation into predictable, enterprise-ready software engineering.

References

- [1] J. Becker, N. Rush, E. Barnes, and D. Rein. Measuring the impact of early-2025 AI on experienced open-source developer productivity. *arXiv preprint arXiv:2507.09089*, 2025.
- [2] GitClear. AI Copilot code quality: 2025 data suggests 4x growth in code clones. *GitClear Research Reports*, 2025.
- [3] Google Cloud DORA. *Accelerate State of DevOps Report 2024–2025: AI Adoption and System Stability*. Google, 2025.
- [4] L. Griffin and R. Carroll. Spec driven development: When architecture becomes executable. *InfoQ Architecture Series*, January 2026.
- [5] M. A. Ramos. SDD-First multi-agent orchestration for enterprise development: A zero-trust reference architecture for governing agentic software engineering at scale. *Preprint DOI: 10.13140/RG.2.2.29185.42087*, August 2026.

- [6] A. Karpathy. Guidelines for mitigating common LLM coding pitfalls. Codified in <https://github.com/multica-ai/andrej-karpathy-skills>, 2025–2026.
- [7] A. Mavin, P. Wilkinson, A. Harwood, and M. Novak. Easy approach to requirements syntax (EARS). In *Proc. 17th IEEE International Requirements Engineering Conference*, 2009.
- [8] L. Sampaio. *AI-Assisted SDD: Spec-Driven Development with Gemini, Claude, and ai-sdd*. Self-Published, 2025.
- [9] D. Spiridonov. Agentic QE Framework: Bridging classical testing to autonomous quality engineering. *Quantum QE & Agentic-QE.dev*, 2025–2026. <https://agentic-qe.dev>.
- [10] R. Cohen. The PACT principles for autonomous agent governance. *Agentics Foundation Whitepapers*, 2024–2025.
- [11] M. Feathers. *Working Effectively with Legacy Code*. Prentice Hall, 2004.
- [12] M. Fowler. Strangler Fig application. <https://martinfowler.com/bliki/StranglerFigApplication.html>, 2004–2020.